



MUCHANGI & ASSOCIATES

Advocates · Data Protection & Technology Law

REGISTRATION GUIDE SERIES

KPLR / RG / 001 / 2026

ODPC Registration for Health Service Providers

A sector guide to registration, patient-data safeguards and correction-notice pitfalls for hospitals, clinics, laboratories and allied health providers in Kenya.



HEALTHCARE SECTOR · ODPC REGISTRATION · SENSITIVE PERSONAL DATA · PATIENT RECORDS

AUTHOR

Patrick Muchangi

PUBLISHED

September 2026

SERIES

Kenya Privacy Law Review

ADVANCING EXCELLENCE IN PRIVACY, TECHNOLOGY & AI GOVERNANCE

ODPC Registration for Health Service Providers

A Sector Guide for Hospitals, Clinics, Laboratories and Allied Health Providers in Kenya

PUBLICATION DETAILS

REFERENCE

KPLR/RG/001/2026

EDITION

First Edition · Version 1.0

PUBLISHED

September 2026

AUTHOR

Patrick Muchangi, Advocate of the High Court of Kenya

PRACTICE AREAS

Data Protection & Privacy · ODPC
Disputes & Appeals

SECTOR

Healthcare

SPEAK TO THE FIRM

CALL

0722 878 607

WHATSAPP

0736 358 938

EMAIL

consult@dataprivacyadvocates.co.ke

WEBSITE

dataprivacyadvocates.co.ke

.....

This Guide is published as a free client-education resource by Muchangi & Associates Advocates. For advice on your own facility, contact the firm directly.

KENYA PRIVACY LAW REVIEW · REGISTRATION GUIDE SERIES

ODPC Registration for Health Service Providers

A sector guide for hospitals, clinics, laboratories and allied health providers in Kenya.

IN THIS GUIDE

01. Introduction
02. The Legal and Regulatory Framework
03. Why Registration Is Mandatory for Every Health Service Provider
04. Controller, Processor — or Both?
05. Registration Tiers and Fees
06. Information the ODPC Will Expect to See
07. Why Applications Get Returned: Sector-Specific Pitfalls
08. Step by Step: Registration and Correction Notices
09. Beyond Registration: Related Compliance Obligations
10. Case in Focus
11. Practical Compliance Checklist
12. Conclusion

AT A GLANCE

- Every health service provider must register as a data controller — and, in several common scenarios, separately as a data processor — regardless of turnover or staff numbers; the general small-business exemption does **not** apply to this sector.
- Statutory registration fees are modest (KES 4,000 to KES 40,000, depending on tier), but the real cost of a poorly prepared application is **time**: each rejected application requires a fresh submission and a fresh fee.
- Patient information is sensitive personal data under the Act, which raises the evidentiary bar for consent, safeguards, and — where care records are hosted offshore — data localisation.
- Recent ODPC determinations against Kenyan hospitals show that the same gaps which trigger registration corrections — undocumented consent, weak safeguards, unclear data flows — are also the gaps driving enforcement awards running into hundreds of thousands of shillings.
- Registration is the starting point of compliance, **not its conclusion**. Facilities that treat it as a one-off form-filling exercise typically resurface either in the correction queue, or in a complaint file.

01 Introduction

Kenya's private healthcare sector ranges from single-doctor clinics to large multi-specialty hospitals, and nearly all of it now runs on some form of electronic patient record, laboratory information system, or insurance claims platform. Each of these systems processes personal data — much of it sensitive health data — about patients, staff, and third parties such as next of kin and referring practitioners. The Data Protection Act, 2019 (“the Act”) requires every entity that determines the purpose and means of processing that data to register with the ODPC before it may lawfully act as a data controller, and separately requires anyone processing that data on another's behalf to register as a data processor. This Guide translates that obligation into a practical methodology for health service providers, with particular attention to the reasons Kenyan facilities most often see their applications sent back for correction.

02 The Legal and Regulatory Framework

The registration obligation arises from section 18 of the Act, given operational effect by the Data Protection (Registration of Data Controllers and Data Processors) Regulations, 2021 (Legal Notice No. 207 of 2021) (“the Registration Regulations”), which took effect on 14 July 2022. Registration sits within the Act's broader constitutional foundation: Article 31 of the Constitution of Kenya, 2010 guarantees the right to privacy, and the Act — together with the Data Protection (General) Regulations, 2021 (“the General Regulations”) — gives that right specific content for the health sector through section 46 (personal data relating to health) and section 47 (further categories of sensitive personal data).

03 Why Registration Is Mandatory for Every Health Service Provider

The Registration Regulations exempt data controllers and processors with an annual turnover below KES 5,000,000 and fewer than ten employees from mandatory registration — but only where the entity does not fall within a list of sectors the Regulations treat as inherently higher-risk regardless of size. “Health administration and provision of patient care” is one of those sectors, alongside financial services, education, insurance, hospitality and several others. A facility that would otherwise qualify for the small-business exemption on size alone must still register, because the exemption requires both conditions to be satisfied together, and requires that the entity not operate in an excluded sector.

PRACTICAL INSIGHT

A two-doctor clinic with an annual turnover well under KES 5,000,000, and a single-outlet pharmacy with three employees, are both required to register. Size is not a defence available to health service providers, and this is precisely the point most first-time applicants misunderstand — many assume the exemption applies to them because they are small, without checking whether their sector is excluded from it.

04 Controller, Processor — or Both?

A hospital or clinic is ordinarily a data controller in respect of its own patient and staff records: it determines why that data is collected and how it will be used. Many facilities are, in addition, a data processor in specific arrangements — for example, where the facility processes results on behalf of a referring hospital or a corporate client's occupational-health programme, where it processes claims-related data strictly on the instructions of an insurer or the Social Health Authority, or where it operates an outsourced records or billing function for an affiliated clinic. Where a facility performs both roles, the Registration Regulations require two separate applications and two separate fees — one as controller, one as processor. Facilities frequently under-declare a processor role that exists alongside their primary controller role, and this is itself a common cause of correction.

05 Registration Tiers and Fees

Private-sector data controllers and processors are classified into three tiers based on annual turnover and employee numbers, with distinct fees for public bodies and for charitable or religious health facilities such as mission hospitals.

Tier	Size Criteria	Registration Fee (once-off)
Micro & Small	1–50 employees; turnover up to KES 5,000,000	KES 4,000
Medium	51–99 employees; turnover KES 5,000,001–50,000,000	KES 16,000
Large	More than 99 employees; turnover above KES 50,000,000	KES 40,000

Tier	Size Criteria	Registration Fee (once-off)
Public / Faith-Based / Charitable Health Facilities	Regardless of turnover or staff numbers	KES 4,000

A certificate of registration is valid for 24 months from the date of issue and must be renewed at least 30 days before expiry; renewal fees are lower than initial registration fees (currently KES 2,000 for Micro & Small facilities, KES 9,000 for Medium, and KES 25,000 for Large). Where a facility registers as both controller and processor, both certificates must be tracked and renewed independently.

06 Information the ODPC Will Expect to See

Beyond basic establishment details — a certificate of incorporation or business registration and a KRA PIN — a complete application requires a clear and internally consistent description of the facility's data processing activities:

- **Categories of data subjects processed** — typically patients, staff, next of kin, suppliers, and, for teaching or referral facilities, students or trainees.
- **Categories of personal data processed**, including the sensitive categories specific to a health setting: health status and clinical history, biometric data where used for patient identification or access control, and genetic data where applicable.
- **The specific purposes** for which data is processed — clinical care, billing and claims, statutory public-health reporting, research, and internal administration should be distinguished rather than bundled into a single generic purpose.
- **Recipients** to whom data is disclosed — commonly the Social Health Authority, private insurers, referral laboratories and hospitals, and public health authorities.
- **Any transfer of data outside Kenya** — for example, a cloud-hosted electronic medical record or telemedicine platform with servers outside the country.
- **The safeguards in place** to protect the data — access controls, encryption, visitor and access logs, a written information security policy, and a patient-facing privacy notice.

07 Why Applications Get Returned: Sector-Specific Pitfalls

In our experience advising health service providers, the following gaps account for the great majority of correction notices issued against hospital and clinic applications.

COMMON MISTAKE — INCOMPLETE DATA INVENTORY

Listing “patients” as the only data subject category and “patient care” as the only purpose, without separately identifying staff, next-of-kin, billing, and research uses. The ODPC expects the inventory to mirror how the facility actually operates, not a one-line summary.

COMMON MISTAKE — UNDER-DESCRIBED SAFEGUARDS

Stating that data is “kept securely” without identifying specific technical and organisational measures. A reviewing officer cannot verify an unspecified claim, and generic language is one of the most frequently cited grounds for correction.

COMMON MISTAKE — WRONG TIER CLASSIFICATION

Declaring a turnover or staff count that does not match the facility’s actual establishment documents, often because seasonal or locum staff are omitted, or because turnover is understated relative to filed accounts.

COMMON MISTAKE — UNDISCLOSED RECIPIENTS

Omitting the Social Health Authority, private insurers, or referral laboratories from the list of recipients, typically because these disclosures are treated as “routine” rather than as data-sharing events requiring disclosure.

COMMON MISTAKE — MISMATCHED REGISTRATION DETAILS

Differences between the applicant’s name, KRA PIN, or business registration details on the ODPC form and on the underlying certificate of incorporation or business name registration.

COMMON MISTAKE — OVERLOOKED DATA LOCALISATION FOR OFFSHORE-HOSTED RECORDS

Section 50 of the Act and regulation 26 of the General Regulations require certain categories of processing — including the provision of primary or secondary health care in Kenya — to be processed through a server or data centre located in Kenya, or to retain at least one serving copy in a Kenyan data centre. A facility using a foreign-hosted electronic medical record or telemedicine platform should confirm this requirement is addressed before it is raised as a correction, and should treat it as a cross-border transfer question in its own right. This overlaps with, and should be read alongside, the firm's Practice Note on Cross-Border Data Transfers (KPLR/PN/003/2026).

08 Step by Step: Registration and Responding to a Correction Notice

- Prepare the data inventory and supporting documents set out in section 6 above before opening the online application, rather than while completing the form.
- Submit the application through the ODPC's online portal and pay the applicable tier fee.
- The application is reviewed following confirmation of payment. Where the Data Commissioner is satisfied, a certificate of registration is issued within 14 days.
- Where the Data Commissioner is not satisfied, a written refusal notice is issued within 21 days, setting out the specific reasons for rejection.
- A rejected applicant may cure the identified deficiencies and make a fresh application — this attracts a new registration fee, which is the principal reason getting the first submission right matters commercially, not only administratively.
- Once issued, the certificate is valid for 24 months and must be renewed at least 30 days before expiry.
- Any material change in the facility's particulars after registration — a change of premises, ownership, or processing activity — must be notified to the ODPC in writing within 14 days of the change.

09 Beyond Registration: Related Compliance Obligations

Registration is a threshold obligation, not a complete compliance programme. Health service providers should, in parallel, address the following:

- **Appointment of a Data Protection Officer**, required where the facility processes sensitive personal data at scale or conducts systematic monitoring of data subjects — a threshold most hospitals and diagnostic laboratories meet by the nature of their operations.
- **A Data Protection Impact Assessment** before undertaking high-risk processing, such as the deployment of a new patient-facing app, a biometric access-control system, or a research database drawing on identifiable patient records.
- **A clear, patient-facing privacy notice** explaining what data is collected, why, and with whom it is shared, in language a patient can reasonably be expected to understand.
- **Written data processing agreements** with referral laboratories, cloud EMR vendors, billing bureaus, and any other party that processes patient data on the facility's behalf.
- **A breach-response procedure** calibrated to the Act's notification timelines — notification to the ODPC without undue delay, and in any event within the statutory window, together with prompt processor-to-controller notification where a vendor is involved.

10 Case in Focus

MERCELINE AKOTH ODEYO V ST. LUKE ORTHOPAEDIC & TRAUMA HOSPITAL ELDORET — ODPC COMPLAINT NO. 2125 OF 2025, DETERMINATION OF 16 MARCH 2026

Facts. The complainant received test results belonging to another patient with a similar first name, on two separate occasions, and the hospital additionally shared her sensitive health data with a third-party laboratory. The hospital argued the mix-up was an isolated administrative error attributable to its referral laboratory, and relied on consent as the lawful basis for the disclosure.

Finding. The Data Commissioner held that the burden of proving a lawful basis for processing sensitive personal data rests with the data handler, not the complainant, and that the hospital had not demonstrated documented, informed consent — verbal assurances of consent do not meet the evidentiary threshold the Act requires for sensitive data. The hospital was found to have inadequate technical and organisational measures in place to protect patient data.

Outcome. The hospital was ordered to compensate the complainant KES 525,000, calculated with reference to the nature and extent of the violation and the sensitivity of the data involved.

Relevance to registration. The same weaknesses the ODPC identified here — an undocumented consent basis and an unspecific description of safeguards — are, in our experience, the exact weaknesses that cause a registration application's data inventory and safeguards sections to be returned for correction. A facility that cannot describe its safeguards with precision at registration stage often cannot evidence them at complaint stage either.

This determination is not isolated. In December 2025, the ODPC ordered The Nairobi Hospital to pay KES 500,000 after a patient's image, recorded during a visit, was used in a promotional advertisement without consent — a breach of sections 32(1) and 37 of the Act. Separately, the ODPC issued an enforcement notice against Aga Khan University Hospital after a staff member inappropriately contacted a patient following a hospital visit, contrary to sections 25, 41 and 46 of the Act, directing the hospital to implement corrective measures within 30 days. Taken together, these determinations confirm that ODPC scrutiny of the health sector is active and intensifying, and that registration should be treated as the first step in a continuing compliance obligation rather than a box to be ticked once.

11 Practical Compliance Checklist

BEFORE YOU APPLY

- ☒ Confirmed the facility's correct tier by cross-checking staff numbers and turnover against filed accounts and payroll records.
- ☒ Confirmed whether the facility must register only as a controller, or additionally as a processor for any third-party arrangement.
- ☒ Prepared a complete data inventory: data subjects, categories of data, purposes, and recipients, each stated separately rather than bundled.
- ☒ Documented specific technical and organisational safeguards, not a general assurance of security.
- ☒ Identified any offshore hosting or processing arrangement and confirmed whether it engages the section 50 localisation requirement.
- ☒ Gathered establishment documents (certificate of incorporation or business registration, KRA PIN) and confirmed they match the application exactly.

AFTER YOU APPLY

- ☒ Diarised the 14-day review window and the 21-day refusal-notice window.
- ☒ If a correction or refusal notice is received, addressed every point raised before resubmitting, rather than the most obvious one.
- ☒ Diarised the 24-month certificate expiry and the 30-day renewal deadline.
- ☒ Established a process to notify the ODPC within 14 days of any material change in the facility's particulars.

ONGOING

- ☒ Appointed or designated a Data Protection Officer where the facility processes sensitive data at scale.
- ☒ Put in place a patient-facing privacy notice and written agreements with processors (referral labs, cloud EMR vendors, billing bureaus).
- ☒ Established a breach-response procedure with clear internal escalation and notification timelines.

12 Conclusion

For a Kenyan health service provider, ODPC registration is not discretionary and cannot be avoided on the grounds of size. The sector's mandatory status, combined with the sensitivity of the data involved, means applications are read more closely than most — which is precisely why a well-prepared, internally consistent first submission is worth the additional time it takes to assemble. Facilities that treat their data inventory, safeguards description, and processor arrangements with the same rigour they apply to clinical governance will generally clear registration without correction, and will simultaneously have gone a long way toward the wider compliance obligations — consent documentation, safeguards, breach response — that recent ODPC enforcement activity shows Kenyan hospitals are now being held to.

KEY TAKEAWAYS

- Every health service provider must register as a data controller — and, in several common scenarios, separately as a data processor — regardless of turnover or staff numbers; the general small-business exemption does **not** apply to this sector.
- Statutory registration fees are modest (KES 4,000 to KES 40,000, depending on tier), but the real cost of a poorly prepared application is **time**: each rejected application requires a fresh submission and a fresh fee.
- Patient information is sensitive personal data under the Act, which raises the evidentiary bar for consent, safeguards, and — where care records are hosted offshore — data localisation.
- Recent ODPC determinations against Kenyan hospitals show that the same gaps which trigger registration corrections — undocumented consent, weak safeguards, unclear data flows — are also the gaps driving enforcement awards running into hundreds of thousands of shillings.
- Registration is the starting point of compliance, **not its conclusion**. Facilities that treat it as a one-off form-filling exercise typically resurface either in the correction queue, or in a complaint file.

AUTHOR'S PERSPECTIVE

Registration corrections are rarely about the ODPC being difficult; in nearly every file we have reviewed, the correction traces back to an application that described the facility's data processing more vaguely than the facility actually operates. Hospitals keep meticulous clinical records as a matter of professional discipline — the registration exercise simply asks that the same discipline be applied to describing how patient data moves through the organisation. Facilities that do this well at registration stage tend to find every downstream compliance obligation easier to meet.

How We Can Help. We advise hospitals, clinics, laboratories and allied health providers on ODPC registration, correction notices, and the wider compliance obligations that follow. If any part of this Guide describes your facility, we would be glad to talk it through with you.

CALL THE FIRM**0722 878 607****WHATSAPP****0736 358 938****ONLINE****dataprivacyadvocates.co.ke****MP****MUCHANGI PATRICK**

Advocate of the High Court of Kenya · Founder, Muchangi Patrick & Associates Advocates. Patrick Muchangi is a boutique-practice advocate specialising in data protection, privacy, AI governance and technology law. He is a Certified Professional Mediator, holds an LL.B from the University of Nairobi and a Post-Graduate Diploma from the Kenya School of Law, and edits the Kenya Privacy Law Review.

RECOMMENDED CITATION

Muchangi & Associates Advocates, “ODPC Registration for Health Service Providers: A Sector Guide for Hospitals, Clinics, Laboratories and Allied Health Providers in Kenya”, Registration Guide No. 001, KPLR/RG/001/2026 (September 2026).

This Guide is prepared for general informational and educational purposes as part of the Kenya Privacy Law Review series on data protection, privacy, and AI governance. It does not constitute legal advice and should not be relied upon as a substitute for advice from qualified Kenyan counsel on the specific facts of any facility's operations. Reading this publication does not create an advocate-client relationship with Muchangi Patrick & Associates Advocates.